

RISK MANAGEMENT PLAN #1

Revision 0 Date: 11/18/2025

System/Asset Name: SW – 005 iCloud

Risk Description and Consequences:

Threats: Default or Weak Administrative Passwords; Shared Account Credentials; Single Point of Failure in Back-Up Data; Required Payment to Maintain Access (Subscription).

Description: Unauthorized Access and Loss of Availability leading to a data breach, data loss, or ransomware event impacting the availability of critical back-up data stored on the iCloud service.

Consequence: Major Loss of availability or integrity of network device backup data, resulting in inability to restore critical network configurations or user data in the event of a system failure. This leads to prolonged service disruption and the potential complete loss of data.

Mitigation Strategies:

What is being done to minimize the probability or consequence of the risk?

- Strong Authentication: Implement and enforce a policy of strong, unique passwords for all accounts accessing the iCloud service, especially administrative accounts.
- Account Hygiene: Prohibit the use of shared accounts. Review and audit all user accounts quarterly, removing unnecessary permissions and accounts. Implement two-factor authentication on iCloud devices for log-in, which will require a code sent to another device be entered before logging in.
- Data Redundancy (3-2-1 Rule): Ensure that the iCloud backup is not the single point of failure. Implement a secondary, offline, and separate backup solution (e.g., local server or tape storage) that is not connected to the network and cannot be accessed by the same credentials.
- User Training: Conduct mandatory training on phishing, social engineering, and password security for all people with access to the cloud environment.
- Access Review: Grant access only to personnel who require it to function on the network (such as Austin).

Contingency Actions and Trip Wires:

Trip Wires/Indicators that the risk is happening:

- Alert: Multiple failed login attempts (especially for administrative accounts).
- Notification: Unexpected or unsolicited two-step authentication access request or unexpected password change notifications (e.g., email or text).
- Observation: Unexpected files being added, deleted, or encrypted (e.g., files with .lock or .ransom extensions).
- User Report: People (Austin or Myself) reporting a system lock-out or a ransom note appearing on their screen or receiving an extortion demand via email.

Actions to take upon identification that the risk is happening:

- **Isolate:** Immediately disable the compromised account and isolate any systems suspected of originating the unauthorized access. This would be done through contacting the Cloud Service Provider (Apple Support) and informing them of the attempted breach/breach so that they can lock the Cloud on their end as well.
- **Contain:** If data has been encrypted or deleted, immediately disconnect the iCloud service from the network to prevent further spread (e.g., syncing back corrupted data).
- **Assess/Notify:** Execute the Notifications list below. Determine the scope of data loss or compromise.
- **Restore:** Initiate the recovery process using the secondary, offline backup solution (the separate backup defined in the Mitigation Strategy) to restore service availability. Do not pay a ransom.

Resources needed: List all that are needed including: training, backups, software/hardware

- **Software/Hardware:** Secondary backup hardware (e.g., NAS or dedicated backup server) and software licenses.
- **Backups:** Up-to-date, tested, and verifiable secondary backup copies stored offline.
- **Training:** Incident Response training on cloud service containment and data recovery protocols.
- **Personnel:** Austin and I will work towards complete system restoration and forensic analysis.

Notifications: List contacts needed to be made should risk happen

- Jane Stashi (Initial high-level awareness and to direct containment/recovery)
- Austin Stashi (Initial high-level awareness and to direct containment/recovery)
- Legal Counsel: (For regulatory/compliance assessment)
- Cloud Service Provider (Apple Support): (To report the breach and gain technical assistance)

Subject Matter Expert/Person Responsible for implementing plan

- Austin Stashi – responsible for Apple support response outreach (Jane Stashi will perform this should Austin be unavailable or unable to).
- Apple Support – responsible for providing technical assistance to stop the breach and providing necessary technical support to restore data from Apple's end
- Jane Stashi – responsible for restoring data from internal end.

Date Plan Must be Ready: 12/01/2025

Approvals: List all who need to approve the plan

- Jane Stashi
- Austin Stashi

RISK MANAGEMENT PLAN #2

Revision 0 Date: 11/18/2025

System/Asset Name: Home Network System (Device: NW – 001 Eero Pro E6 (Router))

Risk Description and Consequences:

Threats: Default or Weak Administrative Passwords; Wireless Management Port Exposure; Weak Wireless Passwords.

Description: Unauthorized access to the router's configuration due to weak or default passwords, allowing an attacker to intercept, redirect, or monitor network traffic, or completely disable Internet access.

Consequence: Major Loss of Integrity and Availability of the network, leading to a complete network outage, successful Man-in-the-Middle (MITM) attacks, or the installation of malicious firmware, compromising all connected devices. This would cause major financial loss and loss of data and network functionality to the users.

Mitigation Strategies: What is being done to minimize the probability or consequence of the risk?

- Strong Administration Password: Change the default administrative password immediately and enforce a unique, complex password using a password manager.
- Wireless Security: Ensure the Wi-Fi network uses WPA3 or WPA2/WPA3 Mixed Mode encryption with a strong, non-dictionary passphrase. Change the Wi-Fi password every 90 days.
- Remote Access Control: Disable remote management of the router (Management Port Exposure) unless necessary. If required, limit access to specific, known IP addresses and use a VPN.
- Regular Firmware Updates: Enable automatic firmware updates to patch known vulnerabilities.
- Network Segmentation: Use the Eero's guest network feature to isolate untrusted devices from critical systems.

Contingency Actions and Trip Wires:

Trip Wires/Indicators that the risk is happening

- Alert: Unexpected/unauthorized login success messages to the router's management application (Eero app).
- Observation: Unexpected changes to the network name (SSID), Wi-Fi password, or DNS settings reported in the Eero app.
- User Report: Widespread and simultaneous loss of Internet connectivity across all devices without a known ISP issue.
- Observation: Network devices being unexpectedly blocked or seeing SSL certificate warnings when browsing trusted websites (indicating traffic interception).

Actions to take upon identification that the risk is happening

- Isolate: Immediately unplug the router's WAN cable (Internet source) to contain the compromise and prevent external communication. Contact
- Contain: If physical access is possible, perform a factory reset of the Eero router immediately to clear any unauthorized configurations or installed firmware.
- Assess/Notify: Execute the Notifications list below. Physically inspect the router for any signs of tampering or indicators of compromise.

- **Restore:** Reconfigure the router from scratch using a known-good configuration. Immediately set a new, unique administrative password and the strong wireless passphrase. Reconnect the WAN cable and monitor traffic for anomalies.

Resources needed:

List all that are needed including: training, backups, software/hardware

- **Software/Hardware:** A spare, pre-configured router (e.g., a secondary Eero unit) to facilitate a quick swap if the primary unit is compromised beyond immediate recovery.
- **Backups:** A **recent, exported copy** of the router's configuration file stored securely and offline.
- **Training:** Training for Jane and Austin on recognizing suspicious network activity and performing a factory reset and initial router configuration.
- **Personnel:** Austin and I will be responsible for contacting the internet service provider (Eero Support and/or Vexus) to notify them of the attempted breach as well as to get assistance with reconfiguring and monitoring the network post-incident.

Notifications: List contacts needed to be made should risk happen

- **Jane Stashi:** Initial high-level awareness and authorization for full network outage; contact for Eero support.
- **Austin Stashi:** Initial high-level awareness and authorization for full network outage; contact for Eero support.
- **ISP/Cloud Service Provider (Vexus/Eero):** To report potential network hardware breach and gain technical assistance.

Subject Matter Expert/Person Responsible for implementing plan

- Austin Stashi – responsible for Eero response outreach and restoring devices from the internal end (Jane Stashi will perform this should Austin be unavailable or unable to).
- Vexus Support – responsible for providing technical assistance to restore the network from Vexus' end.

Date Plan Must be Ready: 12/01/2025

Approvals: List all who need to approve the plan

- Jane Stashi
- Austin Stashi